



SOCIAL ENGINEERING

Technical Report & Documentation

Intern Name: Arsalan Rasool Rather

Organization: CyArt

Program: Red Teaming Internship

Week: Week 3

Tools Used:- SET (Social Engineer Toolkit), PhoneInfoga, Maltego



1. Objective

This task focuses on simulating a social engineering attack in a controlled lab environment. The intern will use PhoneInfoga to gather open-source intelligence (OSINT) on a fictional target, map relationships in Maltego, and simulate a vishing (voice phishing) call using a pre-crafted script. All activities were conducted on fictitious targets in an isolated environment.

2. Lab Environment & Tool Setup

The following tools were installed and configured prior to beginning the exercise. All activities were performed in a sandboxed environment with no real targets.

2.1 Tools Overview

Tool	Source / Install	Purpose
SET	github.com/trustedsec/social-engineer-toolkit	Social engineering & phishing toolkit
PhoneInfoga	github.com/sundowndev/phoneinfoga	OSINT on phone numbers (passive recon)
Maltego	maltego.com (Community Ed.)	Relationship mapping & OSINT visualisation
Kali Linux	kali.org	Attacker OS for all tools



3. Intel Gathering

OSINT was collected on a fictitious target (TID001) using PhoneInfoga for phone number reconnaissance and Maltego for relationship mapping. This phase maps to MITRE ATT&CK T1593 – Search Open Websites/Domains.

3.1 PhoneInfoga – Phone Number Reconnaissance

PhoneInfoga was used to perform passive reconnaissance on the target phone number. The tool queries multiple public sources including Google, Numverify, and social platforms without directly contacting the target.

Command Used:

```
phoneinfoga scan -n +1-555-1234
```

```
phoneinfoga serve (for web UI)
```

3.2 Intel Gathering Log

The table below records all data collected on the fictitious target during the OSINT phase:

Target ID	Data Source	Information Gathered	Risk Level	Notes
TID001	PhoneInfoga	Phone: +1-555-1234 Country: US Carrier: AT&T	Medium	Number confirmed active; linked to LinkedIn profile
TID001	Google OSINT	Name: John Doe Job: IT Support, AcmeCorp	High	LinkedIn profile publicly visible
TID001	PhoneInfoga	Email pattern inferred: jdoe@acmecorp.com	High	Based on company naming convention
TID001	Maltego	Linked to 3 colleagues via LinkedIn graph	Medium	Relationship mapped in Maltego transform

3.3 Maltego Relationship Mapping

Using Maltego Community Edition, the phone number and associated identity were mapped to related entities including email addresses, social media profiles, and organisational links. This provides a visual attack surface for the social engineering phase.



4. Vishing Simulation

A vishing (voice phishing) attack was simulated in a controlled environment using a pre-crafted script. The pretext used was an IT helpdesk impersonation scenario, targeting a fictitious employee at AcmeCorp. No real individuals were contacted at any point.

4.1 Pretext Scenario

Scenario Brief:

Attacker Role: IT Helpdesk Support (impersonating internal IT dept.)

Target Role: John Doe, IT Support Staff, AcmeCorp (fictional)

Pretext: Urgent password reset required due to a simulated system breach alert

Goal: Obtain the target's current credentials / OTP via phone

Vector: Voice call (vishing)

4.2 Vishing Call Script

The following script was crafted and tested in the lab environment. All names and details are fictitious.

[Ring]

Target: Hello, IT Support, John speaking.

Attacker: Hi John, this is Mike from the central IT Security team. How are you today?

Target: Good thanks, what can I do for you?

Attacker: We've detected some unusual login activity on your account in the last 30 minutes. Our system flagged it as a potential breach. I just need to verify your identity and reset your credentials to secure the account.

Target: Oh, that sounds serious. What do you need from me?

Attacker: I've sent a one-time verification code to your registered mobile ending in 1234. Could you read that back to me so I can confirm your identity and lock out the unauthorised access?

Target: Sure, it says... 4 8 2 1.

Attacker: Perfect, thank you John. I've secured the account. You'll receive a new password via email within 10 minutes. Please do not share this with anyone. Have a great day!

Target: Thanks, appreciate it!



4.3 Vishing Scenario Summary (50 words)

Summary:

A fictional IT helpdesk impersonation attack was simulated against AcmeCorp employee TID001. The attacker created urgency by reporting a fabricated breach, then socially engineered the target into revealing a one-time passcode. OSINT gathered via PhoneInfoga and Maltego was used to add authenticity to the pretext. MITRE ATT&CK: T1566, T1598.



5. MITRE ATT&CK Mapping

Technique ID	Tactic	Description	Tool / Method
T1593	Reconnaissance	Search open websites and social platforms for target data	PhoneInfoga, Google OSINT
T1598.001	Phishing for Info	Spearphishing via voice (vishing) to harvest credentials/OTP	SET, Custom Script
T1566	Initial Access	Social engineering pretext used to establish trust	Vishing Call Script
T1056.001	Credential Access	OTP / credential harvested during simulated call	Vishing Simulation

6. Detection & Blue Team Notes

The following indicators and detection opportunities were identified during the simulation. Blue team analysts should implement controls to detect and prevent these social engineering vectors.

Detection Point	Description	Recommended Control
Unsolicited IT calls	Employees receiving unexpected calls claiming IT emergency	Security awareness training
OTP sharing	Target willingly shared OTP — indicates lack of training	Never share OTPs policy + training
Caller ID spoofing	Attacker may spoof internal IT numbers to appear legitimate	Implement call authentication / STIR/SHAKEN
OSINT exposure	Target's number and role publicly accessible via LinkedIn	Limit public profile information



7. Findings and Recommendations

7.1 Key Findings

1. PhoneInfoga successfully collected carrier, region, and linked social media data from a target phone number using only passive OSINT.
2. Maltego effectively mapped the target's relationships, exposing colleagues and email patterns that could be exploited for spear-phishing.
3. The vishing script successfully leveraged urgency and authority bias — common psychological manipulation techniques — to extract an OTP from the fictional target.
4. No technical controls alone can prevent social engineering — human awareness training is the most effective countermeasure.

7.2 Recommendations

- Conduct regular security awareness and anti-phishing/vishing training for all employees.
- Implement a verification callback process — employees should hang up and call the official IT number before sharing any credentials.
- Restrict employee LinkedIn profiles from displaying role, department, and contact details publicly.
- Deploy caller ID authentication (STIR/SHAKEN framework) to reduce spoofed call risk.
- Enforce a strict policy that IT will NEVER request OTPs or passwords over the phone.